

İSTANBUL DENEYAP TEKNOLOJİ ATÖLYESİ

Ders Saatleri : 09.00 - 13.00 - Orta Sabah Grubu (Sınıfdan) - (29 Haziran-8 Temmuz Hafta İçi)

Ders Saatleri : 13.30 - 17.30 - Orta Öğle Grubu (Sınıfdan) - (29 Haziran-8 Temmuz Hafta İçi)



SİBER GÜVENLİK DERSİ

5.Ders: KÖTÜ AMAÇLI YAZILIMLAR



T3 DENEYAP EĞİTMENİ (Hazırlayan ve Sunan): Muhammed Emin Korkunç

(Bilgi Yazar Mühendisi)

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Sabah Grubu

- 09.00 - 09.50: 1. Ders
- 09.50 - 10.00: 1. Mola
- 10.00 - 10.50: 2. Ders
- 10.50 - 11.00: 2. Mola
- 11.00 - 11.50: 3. Ders
- 11.50 - 12.00: 3. Mola
- 12.00 - 13.00: 4. Ders

Öğle Grubu

- 13.30 - 14.20: 1. Ders
- 14.20 - 14.30: 1. Mola
- 14.30 - 15.20: 2. Ders
- 15.20 - 15.30: 2. Mola
- 15.30 - 16.20: 3. Ders
- 16.20 - 16.30: 3. Mola
- 16.30 - 17.30: 4. Ders



Tartışalım: Dijital Dünyada Güvende miyiz?

- **Kötü amaçlı yazılım** denince aklınıza ne geliyor?
- Cihazınıza (telefon, tablet, bilgisayar) hiç **virüs** bulaştı mı?
 - *Neler yaşandı? Sorunu nasıl çözdünüz?*
- Evinizde/cihazınızda **antivirüs yazılımı** kullanıyor musunuz?
 - *Sizce gerçekten gerekli mi, neden?*
- Cihazlarınızı tehlikelerden korumak için hangi **önlemleri** alıyorsunuz?

2- Kötü Amaçlı Yazılımlar

Kötü amaçlı yazılım için alternatif bir diğer terim zararlı yazılımdır. Kötü amaçlı yazılım, terimin aslının uzun hali olan “malicious software” için daha yakın bir çeviri olduğundan tercih edilmiştir. Virüs kavramının kötü amaçlı yazılım anlamında kullanımı teknik olmayan dilde yaygındır, ancak virüs bir kötü amaçlı yazılım türüdür ve tüm kötü amaçlı yazılım türleri için bir çatı terim olarak kullanılması doğru değildir.



Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.



Morris Solucanı (1988)

- **Dönüm Noktası:** Kötü amaçlı yazılımlar 1980'lerde yaygınlaşmaya başladı.
- **İlk Küresel Tehdit:** 1988 yılında üretilen Morris Solucanı (Morris Worm), kendini ağ üzerinden yayarak binlerce Unix sistemini çökertti.
- **Tarihe Geçen Geliştirici:** Robert Morris, kötü amaçlı yazılım geliştirdiği için hapis/para cezası alan ilk kişi oldu.
- **Sızma Yöntemi:**
 - Sistemlerdeki yazılım zafiyetleri
 - Kullanıcıların zayıf ve tahmin edilebilir parolaları

4- KÖTÜ AMAÇLI YAZILIMLARIN TARİHİ VE ÇARPICI ÖRNEKLERİ

! 2010 Sonrası Değişen Tehdit Unsurları

- 1990'lar - 2000'ler: İnternetin yaygınlaşmasıyla zararlı yazılımlar hızla çoğaldı.
- 2010'lar ve Sonrası (Modern Dönem):
 - Amatör yazılımlardan profesyonel siber silahlara geçiş.
 - Temel Amaç: Büyük suç örgütleri tarafından maddi kazanç elde etmek veya ülkeler arası siber savaşlarda üstünlük kurmak.

🔒 WannaCry Saldırısı (2017)

- Yazılım Türü: Fidyeye Yazılımı (*Ransomware*)
- Çalışma Mantığı: Windows sistemlerdeki bir güvenlik açığını kullanarak bilgisayardaki tüm dosyaları şifreledi ve erişilemez hale getirdi.
- Saldırganların Talebi: Dosyaların tekrar açılması karşılığında fidye (Bitcoin) talep edildi.
- Yayılma Yolu: Oltalama (*Phishing*) e-postaları.
- Sonuç: Dünya çapında yüz binlerce bilgisayar kilitlendi, hastaneler ve fabrikalar durdu; devasa maddi kayıplar yaşandı.

5- KÖTÜ AMAÇLI YAZILIMLAR

? Kötü Amaçlı Yazılımlar Neler Yapabilir?

- **Sistem Seviyesinde:**
 - Cihazları yavaşlatabilir veya tamamen kilitleyebilir.
 - Dosyaları silebilir, değiştirebilir veya şifreleyebilir.
- **Hedef Aldığı Kitleler ve Zararları:**
 - Kişiler için: Gizlilik ihlali, kimlik hırsızlığı, maddi kayıp.
 - Kuruluşlar için: Prestij kaybı, ticari sırların çalınması, iş durması.
 - Ülkeler için: Kritik altyapıların (enerji, sağlık, ulaşım) çökertilmesi.

Virüs: Kendisini başka bir programa ekleyerek parazit gibi yaşayan kötü amaçlı yazılımlara virüs denir. Virüsün amacı hem kendisini başka programlara yaymak hem de bilgi çalma, cihaza veya dosyalara zarar verme gibi hedefleri gerçekleştirmektir. Virüslerin bazı genel özellikleri aşağıda verilmektedir: Virüs kendi başına çalışamaz, başka bir programa tutunarak çalışması gerekir. Virüs bağlandığı programın yetkilerine sahip olur. Virüsler kendilerini çoğaltırlar ve yeni programları enfekte ederler.

Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Solucan (Worm):

-  **Kendi Kendine Çalışır:** Virüslerin aksine aktif olmak için bir ana programa ihtiyaç duymaz.
-  **Ağ Üzerinden Yayılır:** Hem sistem içinde hem de bilgisayar ağlarında kendi kopyalarını oluşturarak hızla yayılır.
-  **Gizlenme Taktiği:** Sistemde fark edilmemek için masum ve sıradan isimler kullanır.

7- Truva Atı (Trojan Horse):

 **Aldatıcı Görünüm:** Faydalı veya çok gerekli bir programmış gibi davranır (Örn: "*Bilgisayar Hızlandırıcı*", "*Ücretsiz Antivirüs*").

 **Kullanıcı Eliyle Yükleme:** Dikkat etmeyen kullanıcılar bu vaatlere aldanarak yazılımı kendi rızalarıyla indirip kurarlar.

 **Gizli Tehlike:** Arka planda gizlice sisteme zarar verir, kapıları saldırganlara açar.

- **Casus Yazılım (Spyware):**

- 🕵️ **Amaç:** Kullanıcının haberi olmadan bilgi çalmak ve salıvermek.
- 📝 **Keylogger örneği:** Bastığınız her tuşu (şifreler, mesajlar) kaydeder ve hırsızlara iletir.



- **Reklam Yazılımı (Adware):**

- 💰 **Amaç:** Sürekli reklam göstererek geliştiricisine haksız maddi kazanç sağlamak.
- 🛑 **Etkisi:** Sürekli açılan pop-up (açılır) pencerelerle kullanıcıyı rahatsız eder, sistemi meşgul ederek bilgisayarını yavaşlatır.

- **Fidye Yazılımı (Ransomware):**

- 🔒 **Amaç:** Dosyaları güçlü algoritmalarla şifreleyip kilitlemek.
- 💰 **Tehdit:** Dosyaları geri açmak için para (fidye) talep eder. Fidye ödenmezse dosyaları kalıcı olarak yok edebilir.



Zararlı Yazılımlar Zaman İçinde Nasıl Değişiyor?

- **Kötü amaçlı yazılımların yaygınlığı yıldan yıla değişiklik gösterir.**
- **Truva Atları ve Reklam Yazılımları her dönem çok yüksek sayılarda görülür.**
- **Son Yılların Yükselen Tehdidi: Maddi getirisi yüksek olduğu için Fidye Yazılımları (Ransomware) siber saldırganlar tarafından giderek daha sık kullanılmaktadır.**

10- ÖZET: DÜŞMANIN HEDEFLERİ NELER?

Kötü Amaçlı Yazılımlar Ne Yapmaya Çalışır?

Kötü amaçlı bir yazılım sisteme sızdığında aşağıdaki hedeflerden birini veya birkaçını gerçekleştirir:

-  Veriyi yok etmek veya bozmak.
-  Sisteme zarar vererek çalışamaz hale getirmek.
-  Bilgi çalmak ve uzak sunuculara göndermek.
-  Kullanıcı dosyalarını şifreleyip fidye istemiyle şantaj yapmak.
-  Sistemi "Bot" (Zombi) haline getirmek: Bilgisayarın kontrolünü tamamen uzaktaki bir saldırganla devretmek.
-  Arka Kapı (Backdoor) açmak: Saldırganların sisteme ileride kolayca sızabilmesi için gizli bir giriş yolu yaratmak.

11- TEHLİKENİN KAYNAĞI KİM?

 Kim, Neden Geliştiriyor?

Zararlı yazılımlar arkalarındaki güce ve hedeflerine göre iki ana kaynağa ayrılır:

Yazılım Türü	Temel Hedef	Arkasındaki Güç
Fidye Yazılımları vb.	Doğrudan Maddi Kazanç	Siber Suç Örgütleri
Solucan, Casus Yazılımlar, Arka Kapılar	Gizlice Yayılma, İstihbarat ve Bilgi Toplama	Siber Ordular ve Devlet İstihbarat Kuruluşları

💬 Söz Sizde!

- Çevrenizde, haberlerde veya sosyal medyada duyduğunuz en güncel siber saldırı/virüs olayı hangisiydi?
- Bu saldırıyı gerçekleştirenlerin temel amacı sizce yukarıdaki maddelerden hangisiydi? *(Maddi kazanç mı, istihbarat mı?)*



Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Altın Kural: Kötü amaçlı yazılımlardan korunmanın en etkili yolu, interneti kullanırken tehlikelerden uzak durmaktır.

 İnternete bağlanmadan önce Güvenlik Duvarı (Firewall) mutlaka etkinleştirilmelidir.

 Şüpheli web sayfaları ziyaret edilmemeli, bu sayfalardan otomatik inen dosyalar kesinlikle açılmamalıdır.

 *"Bilgisayarınızda virüs var, temizleyelim"* gibi pencerelere aldanıp şüpheli yazılımlar indirilmemelidir.

 E-posta ekindeki dosyalar açılırken dikkat edilmeli; özellikle .exe uzantılı çalıştırılabilir dosyalar açılmamalıdır.

 Sahibi belirsiz veya başkalarına ait USB flash bellekler bilgisayara takılmamalıdır.

 İşletim sistemi ve kullanılan tüm yazılımlar güncel tutulmalı, güvenlik yamaları yüklenmelidir.

Güvenlik Duvarı (Firewall) Nedir?

- **Görevi:** İnternette gelen ve giden veri paketlerini belirli kurallara göre filtreler.
- **Çalışma Mantığı:**
 - Güvenli/zararsız paketlerin geçişine izin verir.
 - Şüpheli veya zararlı paketlerin geçişini engeller.
- **Türleri:** Hem bilgisayara yüklenen bir yazılım hem de ağa bağlanan özel bir donanım (cihaz) olabilir.

💡 **Üst Düzey Güvenlik İçin:** Ağ güvenlik duvarı, işletim sistemi güvenlik duvarı ve web uygulama güvenlik duvarı gibi farklı katmanların birlikte kullanılması önerilir.



Zararlı Yazılımlar Nasıl Yakalanır?

- Kötü amaçlı yazılımlarla mücadele 3 aşamadan oluşur:
Önleme → **Tespit Etme** → **Temizleme**
- **Antivirüs Yazılımı:** Önleme aşaması yetersiz kalıp zararlı yazılım sisteme bulaştığında onu bulup tanımlayan programlardır.

16- Virüs İmzası (Signature) Nedir?

- Her virüsün kendine özgü bir kod parçası veya davranış örüntüsü vardır; buna virüs imzası denir.
- Antivirüsler, bu imzaları devasa bir veritabanında saklar ve bilgisayarı tararken kodları bu imzalarla karşılaştırır.



Kritik Not: Antivirüs yazılımları sık sık güncellenmelidir. Güncellenmeyen bir antivirüs, yeni üretilen virüslerin imzalarını bilmediği için onları tespit edemez.



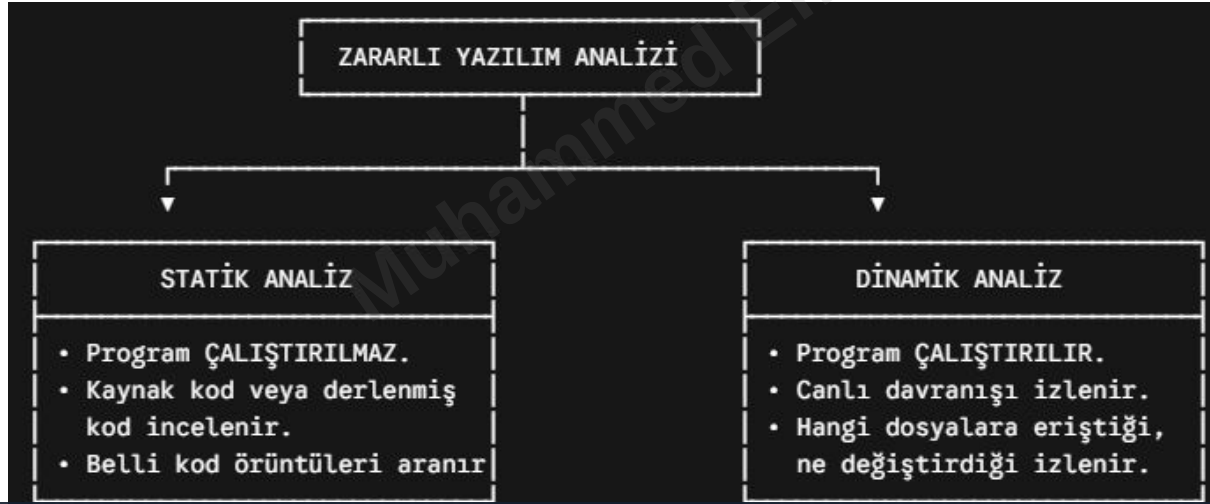
Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.



Statik ve Dinamik Analiz

Kötü amaçlı yazılımları tespit etmek için imza eşleştirmenin ötesinde iki profesyonel analiz tekniği kullanılır:

Not: Bu iki analiz türü çok karmaşık süreçler içerdiğinden çoğunlukla gelişmiş profesyonel araçlar yardımıyla yapılır. (Aboaoja ve diğerleri, 2022).



Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

Temizleme ve Güvenliğe Dönüş

- **Kötü amaçlı yazılım gelişmiş tekniklerle tespit edildikten sonra sistemden tamamen temizlenmelidir.**
- **Temizleme işleminin ardından, sistemin tekrar kararlı ve güvenli hale getirilmesi için gerekli onarımlar yapılır.**

Bilgimizi Test Edelim!

- Bir dosyanın zararlı olup olmadığını anlamak için onu çalıştırmadan kodunu incelemek hangi analiz türüne girer?
- Yeni çıkan bir virüsü eski bir antivirüsün yakalayamamasının sebebi nedir?
- Güvenlik duvarı (Firewall) ile Antivirüs yazılımı arasındaki en temel fark sizce nedir?

20- UYGULAMA ÖRNEĞİ: ANTİVİRÜS KULLANIMI

Microsoft Defender Temel İşlemler

-  **Sistem Tarama Yöntemleri:**
 - **Hızlı Tarama:** Sistemdeki kritik ve virüslerin en çok saklandığı klasörlerin taranması.
 - **Özel Tarama:** Sadece belirli bir dosya, klasör veya USB belleğin seçilerek taranması.
-  **Korumayı Güncelleme:** En yeni virüs imzalarını almak için veritabanının manuel tetiklenmesi.
-  **Ayarları Değiştirme:** Gerçek zamanlı koruma ve bulut tabanlı koruma özelliklerinin açılıp kapatılması.
-  **Denetimli Klasör Erişimi:** Fidye yazılımlarına karşı kritik klasörlerin (Belgeler, Resimler vb.) izinsiz değiştirilmesini engelleme.
-  **Karantina Yönetimi:** Tespit edilen zararlıların sistemden izole edildiği güvenli bölgenin incelenmesi.



Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.



Laboratuvar Çalışması: Kötü Amaçlı Yazılım Tespiti

- Amaç: Kodları çalıştırmadan, hash değerleri ve metin taraması yoluyla zararlı yazılım analizi yapmak.
- Ortam: Kali Linux Terminali

● **ÇOK KRİTİK UYARI (theZoo Projesi):** İnceleyeceğimiz dosyalar gerçek ve canlı kötü amaçlı yazılımlardır! Şifreli ve kilitli olmalarının bir sebebi vardır. Kesinlikle bu dosyaları çift tıklayarak çalıştırmayınız! Sadece komut satırından statik inceleme yapılacaktır.

Projenin Klonlanması ve Dizine Geçiş

- Kali Linux terminal ekranını açınız ve projeyi bilgisayarınıza indirmek için aşağıdaki komutu çalıştırınız:

```
sudo git clone https://www.github.com/ytisf/theZoo
```

İndirme işlemi tamamlandıktan sonra, malware örneklerinin yer aldığı hedef dizine geçiş yapınız:

cd theZoo/malwares/Binaries

ls komutunu kullanarak dizin içerisindeki zararlı yazılım klasörlerini listeleyiniz.

Arşivden Çıkarma ve file Komutu

- Örnek olarak **CryptoLocker_22Jan2014** dizinine giriniz ve **.pass** dosyasındaki şifreyi kullanarak **.zip** arşivini dışarı çıkarınız:

```
cd CryptoLocker_22Jan2014
```

```
sudo unzip CryptoLocker_22Jan2014.zip
```

```
# Parola sorulduğunda klasördeki .pass dosyasının içeriğini giriniz.
```

Çıkarılan dosyanın hangi işletim sistemini hedef aldığını ve mimarisini çalıştırmadan görmek için `file` komutunu kullanınız:

file 1002.exe

⚙️ **Çıktı Analizi:** Komutun ardından PE32 ifadesini göreceksiniz. Bu, dosyanın 32-bit Windows sistemleri için tasarlanmış bir çalıştırılabilir dosya olduğunu gösterir.

strings Komutu ile İpucu Yakalama

- Zararlı dosyanın kaynak kodunda unutulmuş veya açıkta bırakılmış anlamlı metinleri (IP adresleri, URL'ler, hata mesajları) görmek için strings komutunu çalıştırınız:

```
strings 1002.exe
```

? Sınıf İçi İnceleme:

- Çıktıyı yukarı doğru kaydirdığınızda anlamlı bir kelime, web adresi veya kütüphane adı görebiliyor musunuz?
- Geliştiricinin bıraktığı bu dijital izler bize yazılımın amacı hakkında ne tür ipuçları veriyor?

Karma (Hash) Fonksiyonlarının Kullanımı

- Dosyanın içeriğini tamamen benzersiz bir metne dönüştüren ve "dijital parmak izi" sayılan hash değerlerini üretiniz. Bu çıktıları bir sonraki adım için kopyalayınız:

md5sum 1002.exe

sha1sum 1002.exe

sha256sum 1002.exe

 **Unutmayın: Dosyanın içindeki tek bir bit bile değişse bu hash değerleri tamamen değişir. Bu yüzden imza tabanlı tespitte hash değerleri çok önemlidir.**

VirusTotal ile Tehdit İstihbaratı

- Tarayıcınızda şu adrese gidiniz: [virustotal.com](https://www.virustotal.com)
- Üst menüden "Search" sekmesine tıklayınız.
- Bir önceki adımda ürettiğiniz SHA-256 veya MD5 hash değerini arama kutusuna yapıştırıp aratınız.

VirusTotal Search | [e3b0c44298fc1c149afb4c8996fb92427ae41e4649b...] 

Raporu İnceleyelim:

- Dünyadaki kaç farklı antivirüs motoru bu dosyayı "zararlı" olarak işaretlemiş?
- Raporda bu yazılımın ait olduğu aile (Örn: *Ransomware/CryptoLocker*) hakkında ne tür detaylar yer alıyor?



Uygulama Sırası Sizde!

- Kalan süremiz boyunca Binaries klasörü altındaki farklı bir malware dizinine geçiş yapınız.
- Sırasıyla şu adımları işletiniz:
 1. .zip dosyasını şifresiyle açın.
 2. file ile hedef sistemi tespit edin.
 3. strings ile içinde ipucu arayın.
 4. Hash değerini hesaplayıp VirusTotal üzerinde sorgulayın.
- Karşılaştığınız en yüksek yakalanma oranına sahip zararlıyı ve türünü sınıfla paylaşın!

GİRİŞ & BEYİN FIRTINASI

Tartışalım: Dijital Tuzaklar

- Telefonunuza veya e-postanıza hiç güvenilir gelmeyen mesajlar aldınız mı?
 - *Örn: "Tebrikler, hediye kazandınız!" veya "Kargonuz teslim edilemedi, linke tıklayın."*
- Sizce bir mesajın şüpheli olması ne anlama gelir? Hangi detaylar sizi şüphelendirir?
- Oltalama (Phishing) saldırısı terimini daha önce duydunuz mu? Çevrenizden bir örnek verebilir misiniz?
- Sosyal Mühendislik kavramı sizce neyi ifade ediyor? Bir insanı hacklemek mümkün müdür?

31- SOSYAL MÜHENDİSLİK NEDİR?

🧠 İnsan Psikolojisini Hacklemek

Tanım: İnsanları kandırarak, manipüle ederek veya korkutarak saldırganın istediği yönde hareket etmelerini (bilgi paylaşma, para gönderme vb.) sağlama yöntemleridir.

- **Saldırganların Temel Amaçları:**
 - 🗝️ Parola, TC kimlik numarası veya kredi kartı gibi gizli bilgileri ele geçirmek.
 - 💰 Yanlış bilgilerle korkutarak veya boş vaatlerle kandırarak dolandırıcılık yapmak.
- **Kullanılan Kanallar:** Elektronik posta (e-posta), SMS (kısa mesaj), sosyal medya mesajları ve telefon aramaları.



Bu sunumun kopyalanması, paylaşılması ve yazılı izinsiz kullanımı KESİNLİKLE YASAKTIR.

- **Ortalama: Sahte mesajlar ve sahte web siteleri yoluyla gerçekleştirilen en yaygın sosyal mühendislik saldırısı türüdür.**

[Saldırgan] — Sahte E-posta/SMS Gönderir → [Kullanıcı]

[Saldırgan] ← Gizli Bilgileri Ele Geçirir — [Sahte Linke Tıklar & Giriş Yapar]

Çalışma Mantığı:

1. Kullanıcıya banka, kargo şirketi veya sosyal medya platformu gibi görünen sahte bir mesaj gelir.
2. Mesajın içindeki tuzak linke tıklayan kullanıcı, gerçeğine tıpatıp benzeyen sahte bir giriş sayfasına yönlendirilir.
3. Kullanıcı bu sayfaya kullanıcı adı ve parolasını yazdığı anda tüm bilgiler saldırganın eline geçer.



Oltalama Saldırısı Örnek Arşivi

- Dünyadaki gerçek siber saldırganların hazırladığı oltalama örneklerini, kurdukları tuzak cümleleri ve sahte tasarımları incelemek için küresel arşivlerden faydalanabiliriz.

 **İnceleme Adresi:** UC Berkeley Üniversitesi tarafından derlenen gerçek oltalama e-postaları arşivi:

security.berkeley.edu/education-awareness/phishing/phishing-examples-archives
ve

- E-postalarda En Çok Kullanılan Tuzak Kelimeler:
 - "Hesabınız askıya alındı, hemen doğrulayın!"
 - "Şüpheli giriş tespiti, şifrenizi değiştirin."
 - "Faturanız ödenmedi, icra takibi başlanmaması için tıklayın."

Dijital Kimliğimizi Nasıl Koruruz?

Günümüzde sosyal mühendislik ve oltalama saldırıları en çok sosyal medya üzerinden yapılmaktadır. Güvende kalmak için 5 temel kural:

-  **Güçlü Parolalar:** Tahmin edilmesi zor, harf-rakam-sembol içeren parolalar seçilmelidir.
-  **Mahremiyet (Privacy) Ayarları:** Profilimizi, paylaşımlarımızı ve kişisel bilgilerimizi kimlerin görebileceği dikkatlice sınırlanmalıdır.
-  **Bilinçli Paylaşım:** Suç oluşturan, kırıcı söz içeren veya bizi ileride zor durumda bırakacak paylaşımlardan kaçınılmalıdır.
-  **Sahte Hesap Kontrolü:** Tanıdığımız kişilerin adına açılmış yeni/kopya hesaplara karşı uyanık olunmalıdır.
-  **Tuzaklara Basmama:** Gelen mesajlardaki şüpheli linklere tıklanmamalı ve kaynağı belirsiz kampanya mesajları başkalarına yayılarak tuzak büyütülmemelidir.

Sizce Başka Neler Yapabiliriz?

- Sosyal medyanın güvenli kullanımında, az önce saydığımız 5 temel kurala ek olarak başka hangi kuralları ve tavsiyeleri uygulayabiliriz?
- Bir arkadaşınızın hesabının çalındığını ve sizden borç para veya hediye çeki kodu istediğini fark ederseniz, durumu doğrulamak için ilk yapacağınız şey ne olurdu?

Görev Dağılımı ve İçerik Üretimi

- Platform Seçimi: İstediğiniz bir iletişim kanalını seçin: E-posta, SMS veya Sosyal Medya Paylaşımı.
- Çalışma Ortamı: Boş bir Word dosyası açarak mesajınızın içeriğini ve görsel düzenini hazırlayın.

Ana Hedefiniz:

- Karşı tarafı (kurbanı) ikna ederek mesajın içindeki "sahte linke" tıklatmak.
- Gideceği sahte sayfada kullanıcı adı, parola veya kritik bir bilgisini girmesini sağlamak.
- *Taktiklerinizi insan psikolojisini (korku, merak, ödül arzusu) tetikleyecek şekilde seçin.*

Sınıfın En İnanıdırıcı "Oltası" Hangisi?

- **Kriter:** Bir oltalama mesajının başarısı, kurbanın o linke tıklama ihtimali ile ölçülür.

Oylama Yöntemi:

1. Her grup, kendi mesajı dışındaki tüm grupların tasarımlarını dikkatlice inceler.
2. En inandırıcı ve tehlikeli bulduğu 3 mesajı seçer.
3. Bu mesajlara sırasıyla 1, 2 ve 3 puan vererek oyunu kullanır.

 Oylama sonucunda sınıfın en yüksek puanı alan tasarımları tahtaya yansıtılacak ve "Neden bu kadar inandırıcı oldular?" sorusu üzerinden analiz edilecektir.

Süreç Üzerine Tartışalım

- Ürettiğiniz ortalama mesajını siber dünyadaki gerçek örnekler gibi daha da inandırıcı hale getirmek için (görsel veya metinsel) neler ekleyebilirdiniz?
- Sizce siber korsanların hazırladığı en profesyonel ortalama mesajları, hedef kitlelerin yüzde kaçını (.9'unu) kandırmayı başarıyordur?
- Bu etkinlikte siber saldırganların bakış açısını görmek, kendi hesaplarınızı koruma konusunda size nasıl bir farkındalık kazandırdı?

Akıllı Bir Savunma Sistemi Kurmak

- **Soru: Bir mesajın sosyal mühendislik veya ortalama girişimi olup olmadığını otomatik olarak anlayan bir yazılım/program yazmak isteseydiniz, nasıl bir mantık kurardınız?**
- **Gelen kutunuza düşen metinleri incelerken programın ilk bakmasını isteyeceğiniz 3 şey ne olurdu?**

Oltalama Tespit Yazılımı Algoritması

- Format: 2 kişilik gruplar.
- Görev: Gelen e-postaları inceleyip oltalama olup olmadığını ayırt eden bir program mimarisi tasarlamak.

Programınız Hangi Kriterlere Bakmalı?

Tasarımınızı yaparken şu rehber sorulardan faydalanabilirsiniz:

- Fark Faktörleri: Oltalama e-postalarını normal e-postalardan ayıran temel farklar nelerdir? (*Mesaj uzunluğu, aciliyet dili, gönderen adresi vb.*)
- Kelime Filtreleme: Eğer oltalama mesajlarında sık geçen kelimeleri (Örn: "*Hemen tıklayın*", "*Hesabınız bloke oldu*") belirlediyseniz, program bu kelimeleri yakaladığında nasıl bir puanlama yapmalı?
- Kara Liste (Blacklist): Zararlı olduğu bilinen e-posta adreslerinin listesini programınızın içinde nasıl bir kontrol mekanizmasıyla kullanırsınız?

Algoritmalar Yarışıyor

- Süre tamamlandığında, her grup hazırladığı algoritmanın adımlarını veya akış şemasını sınıfa sunacaktır.
- Dinleyici gruplar ve eğitmen sunum yapan ekibe şu yönlerden geri bildirim verecektir:
 - Tasarlanan algoritmanın açıkları / zayıf yönleri neler?
 - Akıllı bir siber saldırgan bu programı atlatmak için nasıl bir hile düşünebilir?
 - Algoritmayı daha güçlü kılmak için ne tür iyileştirmeler yapılabilir?

